QA PASS · FULL RUN, LOGGED IN

Havoc QA Report

Black-box QA of the Havoc admin panel and the Havoc Android player app, done on 11 November 2026. Both were tested before and after logging in: the admin as `admin`, and the app as a test player the owner registered. Everything runs on the **live production backend**, so I only read real data, only changed records I created myself (named `QA_TEST_…`), and didn't make any payments or bookings.

Admin **havoc-admin.cyberboost.io** API **havoc-api.cyberboost.io** App **com.havoc.lasertag 1.0.4 (5)**

Device **Pixel 6 emulator · Android 14**

Summary

1	2	13	13	31
CRITICAL	HIGH	MEDIUM	LOW	CHECKS PASSED

Fix first

- **C-1:** SkipCash payments are in **Sandbox (test) mode on the live system**. Real cards can't pay, so the "Paid" bookings in admin are most likely test payments.
- **H-2:** the add-on prices players see don't match what they're charged. Bookeo calculates the real total, and the app's own Help page says the opposite of the booking screen.
- **H-1:** anyone can crash the app with the link `havoc:///_sitemap`. It's a one-file fix.
- **M-6 / M-7:** paid bookings are stuck in "Pending", and two paid bookings were cancelled with no record of a refund.
- **M-1:** there's no "Forgot password" option. Players who forget their password are locked out.

What works well: the app's core loop is solid. Chat syncs between the app and admin in real time in both directions, losing the connection is handled cleanly, and there were no crashes or JavaScript errors during the logged-in session. HTML typed into chat or offers is shown as plain text and doesn't run, and account deletion is password-protected. The app is a React Native (Expo) build, not Flutter, so it was driven over adb rather than Flutternaut.

Findings ranked by severity

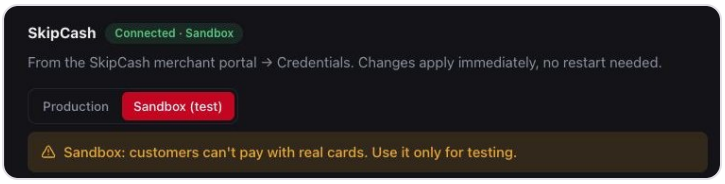
C-1 **CRITICAL** PAYMENTS · ADMIN SETTINGS

SkipCash is set to Sandbox (test) mode on the production system

WHERE Admin → Settings → SkipCash. The badge reads **"Connected · Sandbox"** and the page itself warns: *"Sandbox: customers can't pay with real cards. Use it only for testing."*

IMPACT Any player who taps **Book & pay** in the live app is sent to a SkipCash test page, so no real money is collected. Bookings marked "Paid" in admin (including one for QAR 1,200) were most likely paid with test cards. If unpaid bookings auto-cancel, real customers can lose their slot because they couldn't pay.

FIX Enter the production SkipCash credentials, switch to **Production**, run one small real payment end to end, and check the past "Paid" bookings against the SkipCash merchant portal.



Admin settings on production (IDs cropped out)

H-1 **HIGH** MOBILE · CRASH

The app crashes when it opens a link to `_sitemap`

STEPS

1. Open the link `havoc:///_sitemap` on a phone with the app installed, from a browser, a QR code, a chat message or adb.
2. Or open any unknown link such as `havoc://anything` and tap **Sitemap**.

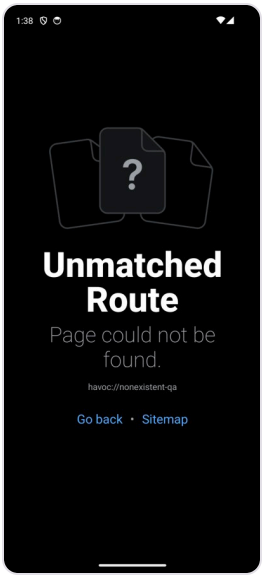
EXPECTED A branded "page not found" screen, or the app's home screen.

ACTUAL The app closes straight away and Android shows "Havoc keeps stopping". This happened 3 times out of 3. It doesn't need a login.

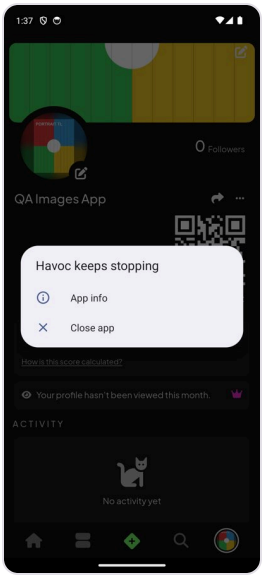
CAUSE Expo Router's built-in developer **Sitemap** screen ships in the production build, and it crashes in release mode.

FIX Add `app/_sitemap.tsx`, which replaces the built-in screen, and have it redirect to the home screen. Also add a custom `app/+not-found.tsx` (see M-2).

```
FATAL EXCEPTION: mqt_v_native
Process: com.havoc.lasertag
com.facebook.react.common.JavascriptException: TypeError: Cannot read property
'origin' of undefined
    at SystemInfo → SitemapInner → NoSSR → Sitemap → … → ExpoRoot
```



Unknown link → developer error page



After tapping Sitemap

H-2 HIGH PAYMENTS · APP + ADMIN

The add-on prices players see aren't what they're charged

EVIDENCE

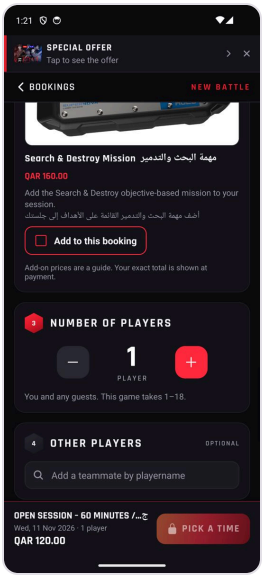
- Admin Settings says add-on prices *"are for display: the amount charged is still the total Bookeo calculates"*.
- The app advertises Search & Destroy at **QAR 160**. Real bookings that include it come to only about QAR 10–20 more than the base price.
- The booking screen says *"Add-on prices are a guide. Your exact total is shown at payment."*, but the Help page says the prices *"are added to the total automatically."* The two screens contradict each other.

IMPACT

Players see one price and pay another. That leads to disputes, lost revenue if Bookeo charges less, or chargebacks if it charges more.

FIX

Use one source of truth. Either sync the add-on prices from Bookeo, or push the app's prices to Bookeo. Then show the same total on the booking screen and on the SkipCash page.



QAR 160, "a guide"

M-1 **MEDIUM** MOBILE + WEB · AUTH

There's no way to reset a forgotten password

WHERE The app's Sign In screen and the admin login. I also searched the code of both apps, and neither has a reset or recovery feature.

IMPACT A player who forgets their password can't book or check their stats. The only route back is to call the venue, so staff have to reset passwords by hand. This also hurts the delete-account page, which needs the password too.

FIX Add a "Forgot password?" link that sends a reset email. The app already sends emails through SMTP2GO.

M-2 **MEDIUM** MOBILE · NAVIGATION

Unknown links show Expo's developer "Unmatched Route" page

STEPS Open `havoc://nonexistent-qa`. An old push notification, a broken QR code or a typo in a shared link would do the same.

ACTUAL An unbranded white-on-black page reading "Unmatched Route / Page could not be found", with the raw link shown and a **Sitemap** link that lists the app's internal screens and then crashes (H-1).

FIX Add `app/+not-found.tsx`: a Havoc-styled screen with a "Back to home" button.

M-3 **MEDIUM** WEB · PUBLIC PAGES

Player-facing pages live on the admin domain and are titled "Havoc Admin"

WHERE `/privacy`, `/terms` and `/delete-account` on `havoc-admin.cyberboost.io`. The app's sign-up screen links players to them, and the browser tab says "Havoc Admin".

IMPACT Players land on a page that looks like staff tooling, and the admin URL gets shared publicly. This is likely also the data-deletion URL listed in the Play Store, which puts the admin domain in a public listing.

FIX Serve these pages from havoc-tlt.com or a player subdomain, and give each one its own title, such as "Privacy policy · Havoc".

M-4 MEDIUM WEB · SECURITY · NEEDS CHECK

The public delete-account form takes a playername and password, so it needs brute-force protection

WHERE `/delete-account` is public and has no CAPTCHA. Entering a playername and password and ticking one box deletes the account permanently.

RISK If the backend doesn't rate-limit or lock out repeated attempts, this form lets someone guess passwords, and a correct guess permanently deletes a player's account. I didn't hammer it, because it's production.

FIX Confirm with the backend team that attempts are rate-limited by IP and by account. Consider an email confirmation step before deleting.

M-5 MEDIUM MOBILE · CONFIG

Android backup is switched on (`allowBackup=true`)

EVIDENCE The package flags include `ALLOW_BACKUP` (from `dumpsys package`). `expo-secure-store` is present, which protects anything stored with it.

RISK Data the app keeps in plain storage (AsyncStorage, caches) is included in device backups and can be pulled off over adb.

FIX Set `android.allowBackup: false` in app.config, or add backup exclusion rules.

M-6 MEDIUM BOOKINGS · ADMIN

Paid bookings stay in "Pending"

EVIDENCE 4 bookings show a payment but are still "Pending", and some of them are for dates that have already passed.

IMPACT Staff can't trust the status column. A payment, or the SkipCash webhook, doesn't move a booking to Confirmed. Sandbox mode (C-1) may be part of the cause.

FIX — Confirm the booking when the payment webhook arrives, and mark past bookings as Completed or No-show.

M-7 **MEDIUM** BOOKINGS · PAYMENTS

Paid bookings were cancelled, with no refund recorded

EVIDENCE — 2 cancelled bookings show money paid, one of them QAR 1,200. Nothing shows whether it was refunded. Both Settings and the app's Help page promise *"once any payment is made, your booking is kept."*

FIX — Block automatic cancellation once a payment exists. Add a "Refunded / Refund pending" state when staff cancel a paid booking.

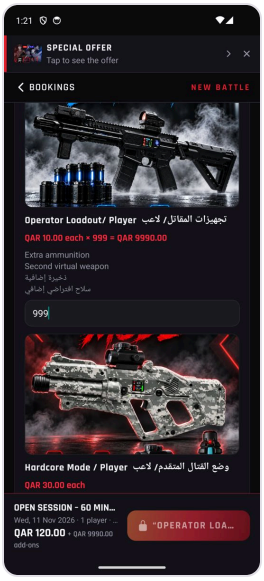
M-8 **MEDIUM** BOOKINGS · APP + ADMIN

"Per player" add-on quantities aren't limited to the number of players

STEPS — In the app, start a booking for **1 player** and type `999` into "Operator Loadout / Player".

ACTUAL — It's accepted: "QAR 10.00 each × 999 = QAR 9,990.00". In admin, an existing 1-player booking has Hardcore ×5 and Full Tactical ×8. Add-ons are also chosen *before* the number of players, so the order of steps doesn't help.

FIX — Ask for the number of players first, and cap per-player add-ons at that number, both in the app and on the server.



999 add-ons, 1 player

M-9 **MEDIUM** BOOKINGS · ADMIN

The admin price estimate leaves out add-ons

ACTUAL When editing a booking, the estimate reads e.g. "1,500 QAR + add-ons", so staff can't quote a customer a total over the phone.

FIX Include the add-ons in the estimate. If the price is still uncertain (H-2), show the total Bookeo calculated.

M-10 MEDIUM STATS · LEADERBOARD

The leaderboard is about 4 weeks out of date, and failed imports don't explain why

EVIDENCE Only 2 stats imports have ever succeeded, the last on 14 October. In the app, the #1 player was last seen playing on that same date. 3 more uploads failed because staff chose the "Game_statistic" PDF instead of "Total_statistic", and the error message doesn't say which file is expected.

FIX Name the expected file in the error ("Upload the Total_statistic report"). Show the date of the last import in admin, and consider a weekly reminder.

M-11 MEDIUM APP · PRIVACY

Every player can browse a list of all players with their "last seen" times

WHERE App → Chat → **All players**. Anyone who registers sees every account's playername and online / "Last seen" status, and can message any of them.

RISK A stranger can track when someone is active and message them out of nowhere. That matters more because the policy allows players from age 13. It also contradicts the "private chat" framing.

FIX Only allow chats with people you've shared a booking with or found by exact playername. Let players hide their "last seen" status, and consider turning it off by default for minors.

M-12 MEDIUM APP · ACCOUNT

Emails are never verified, and players can't edit their profile or change their password

EVIDENCE The test account was registered with `test@test.com` and works fully. Profile shows the email and phone as read-only. There's no "Edit" option and no "Change password".

IMPACT Payment receipts and "payment due" emails go to addresses nobody owns. Combined with M-1 (no password reset), a player with a typo in their email can never recover their account or receive receipts, and staff have to fix everything by hand.

FIX Verify the email at sign-up (code or link), and add Edit profile and Change password screens.

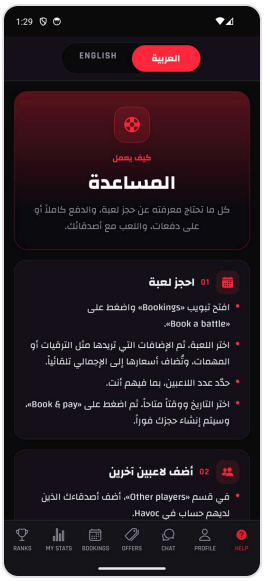
M-13 MEDIUM APP · LOCALISATION

The language switch only translates the Help page

STEPS Help → tap العربية → open any other tab.

ACTUAL Help switches to Arabic (right-to-left), but every other screen stays in English: tabs, bookings, chat, profile and errors. Content in two languages (game names, add-ons) is shown in both at once, and the Arabic part of "Open session – 60 minutes" renders in the wrong order (the "60" sticks to the wrong word).

FIX Apply the language setting to the whole app with i18n, or move the switch somewhere obviously labelled "Help language only".



Arabic Help, English tabs

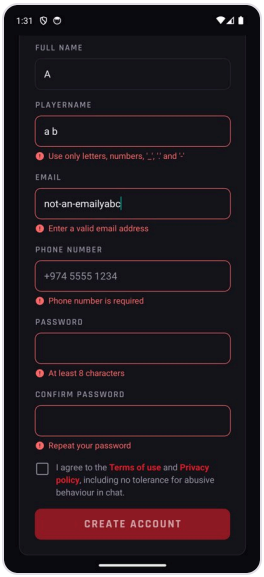
L-1 LOW MOBILE · SIGN-UP

Ticking the Terms checkbox is required, but leaving it unticked shows no error

STEPS Fill or skip the fields, leave "I agree to the Terms..." unticked and tap **Create account**.

ACTUAL Every other field shows a red message. The checkbox gets no highlight and no text. Once all the fields are valid, a player won't know why sign-up isn't working.

FIX Show "Please accept the Terms of use to continue" under the checkbox.



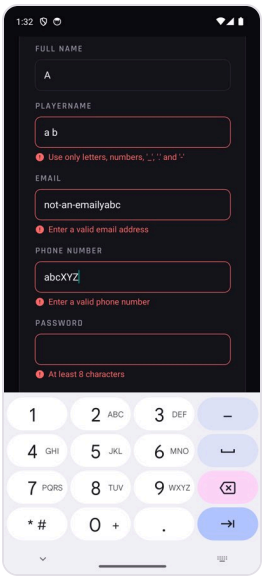
No message on the checkbox

L-2 LOW MOBILE · SIGN-UP

The phone field opens the full keyboard and accepts letters

ACTUAL Typing `abcXYZ` works. It's only rejected afterwards with "Enter a valid phone number".

FIX Set `keyboardType="phone-pad"` and `textContentType="telephoneNumber"`, and consider filling in `+974` automatically.



Letters accepted

L-3 LOW MOBILE · SIGN-UP

A one-letter full name is accepted

ACTUAL Full name `A` passes validation; only an empty name is rejected.

FIX Require at least 2 characters, and ideally a first and last name, since staff use this name at the venue.

L-4 LOW MOBILE · COMPLIANCE

The privacy policy says players must be 13 or over, but sign-up never asks for age

DETAIL The policy says "meant for players aged 13 and over". Sign-up has no date of birth or age confirmation.

FIX Add an "I'm 13 or older" confirmation, or a date-of-birth field.

L-5 LOW MOBILE + WEB · LEGAL PAGES

The privacy policy offers data requests "using the contact details below", but gives no email address

DETAIL The contact section lists only a phone number, the website and in-app chat. Data requests normally need a written channel, which in-app chat can't provide for someone who has deleted their account.

FIX Add a privacy contact email to the privacy and terms pages.

L-6 LOW MOBILE · UX

The Terms and Privacy links leave the app for the phone's browser

ACTUAL Tapping either link opens Chrome. On a fresh phone, Chrome's own "Welcome to Chrome" setup screen appears before the policy loads, in the middle of sign-up.

FIX Open these pages inside the app with `expo-web-browser`, using `openBrowserAsync`.

L-7 LOW MOBILE · PERMISSIONS

The app declares permissions it doesn't appear to use

LIST `SYSTEM_ALERT_WINDOW` (draw over other apps), `USE_BIOMETRIC` / `USE_FINGERPRINT` (no biometric login in the code), `RECEIVE_BOOT_COMPLETED`, legacy storage read/write, and about 20 launcher-badge permissions from Samsung, HTC, Sony, Huawei and Oppo.

RISK Google Play reviews `SYSTEM_ALERT_WINDOW` closely, and the app-info screen looks alarming to players.

FIX Add these to `android.blockedPermissions` in app.config, which already blocks `RECORD_AUDIO`.

L-8 LOW WEB · SERVER

Missing Content-Security-Policy, HSTS without subdomains, and the server version is exposed

HEADERS The response includes `server: nginx/1.24.0 (Ubuntu)` and `strict-transport-security: max-age=31536000`, which has no `includeSubDomains`. There is no `content-security-policy`. X-Frame-Options DENY, nosniff and Referrer-Policy are all set correctly.

FIX Set `server_tokens off;`, add a CSP that limits connections to `havoc-api.cyberboost.io`, and extend HSTS to subdomains.

L-9 LOW WEB + MOBILE · POLISH

Smaller issues

WEB Unknown admin URLs (`/this-page-does-not-exist`) quietly send you to the login page instead of showing a 404.

APK At 109 MB, the APK carries all four CPU types in one file. An app bundle (AAB) or per-CPU builds would cut the download to about a third.

APP On Sign In, the disabled button gives no hint that both fields are required. The dimmed text on dark red is also hard to read.

L-10 LOW ADMIN · LAYOUT

The admin bookings table doesn't fit the screen

ACTUAL At a 1300px-wide desktop window, the Actions column is hidden until you scroll sideways. At phone width the whole page scrolls sideways and the menu is cut off.

FIX Wrap long cells, or collapse rows into cards below about 1100px.

L-11 LOW ADMIN · DATA & WORKFLOW

Smaller admin issues

BOOKINGS

- Cancelled bookings are listed under "Upcoming".
- Add-ons with quantity 0 are still listed.
- Past bookings can still be edited and cancelled.

- Leaving the Edit screen throws away changes without warning, and the filter resets from "All" to "Upcoming".
- There's no booking detail view, and rows aren't clickable.

DATA

- An add-on name is cut off: "Full Tactical Upgrade/ Playe".
- The game "Private Session – / جلسة خاصة" has no English name, and this shows in the app too.
- Phone numbers are stored in mixed formats (+974 vs 8 digits); one has 12 digits, and two accounts share one number. The server doesn't validate phone numbers or check they're unique.

PLAYERS & STATS

- There's no link from the Players list to a player's stats.
- The stats page shows two different "efficiency" numbers (1.71 vs 2.93) with no explanation.
- The KIA card says "best 25", but for KIA a higher number is worse.
- On the leaderboard page, "Players" is highlighted in the menu.

CHATS & OFFERS

- The Reports tab shows only open reports, with no history.
- A player chat has had no reply since 16 October.
- The live offer is titled "Image offer".
- "Show in the app" is ticked by default, so a new offer goes live the moment it's saved.
- Admin says players see messages from "Havoc Admin", but the app shows the sender as "admin".

L-12 LOW APP · POLISH

Smaller app issues

CHAT

- The support account appears as an ordinary player called "admin", always "Offline", even right after it replies. It isn't pinned or verified, so a player could register a look-alike name to impersonate staff.
- Offline, the chat history disappears and the contact shows as "..." with a "?" avatar. After reconnecting, the screen doesn't recover until you leave and reopen it. The "Not sent · tap to retry" option does work.

BOOKING

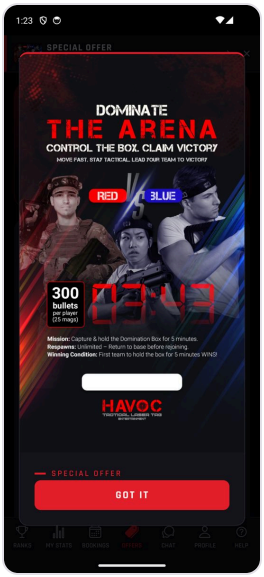
- Tapping Back throws away the whole booking with no "Discard?" prompt.
- The add-on quantity box strips characters silently, so typing `1.5` becomes `15`.

OFFERS

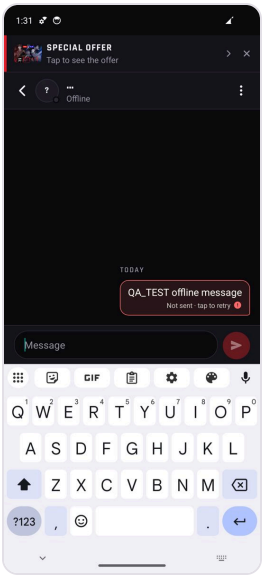
The only offer is an image with no title, price, dates or "Book this" button. The artwork contains an empty white button-shaped box.

OTHER

- The "Hide offers" banner comes back after every app restart.
- Sign out has no confirmation.
- At 1.3× font size, the tab labels are cut off ("MY STA...", "BOOKI...").



Offer: image only, no price



Chat while offline

L-13 LOW APP · ACCESSIBILITY

Screen readers read out raw HTML codes

ACTUAL The labels that TalkBack reads contain encoded text: game descriptions include `
`, "Search `&` Destroy", "BOOK `&` PAY", and emoji as `👍`. After a failed delete attempt, the Delete button's label stays "busy".

FIX Decode HTML entities from the API before rendering, and clear the busy state when a request fails.

What was tested

Mobile app · logged out

- PASS — Installs and launches on Android 14 with no errors in the startup logs
- PASS — Doesn't ask for camera or notification permission on first launch
- PASS — Sign In button stays disabled until both fields are filled, and the password is masked
- PASS — Sign-up checks playername characters, email format, phone format, password length and that the two passwords match
- FAIL — Terms checkbox error, phone keyboard, name length (L-1 to L-3)
- PASS — Links straight to logged-in screens send a logged-out user to Sign In
- FAIL — Unknown links and the sitemap link (H-1, M-2)
- PASS — Locked to portrait; force-close, relaunch and no-internet launch don't crash
- PASS — Not a debug build, and no API keys or secrets in the app code

Mobile app · logged in

- PASS — Ranks: podium, list and player stats pages load, and "not ranked yet" state for new players
- PASS — My Stats empty state for a new player
- PASS — "Read this before you book" popup honours "Don't show again" after a restart
- PASS — Booking: game list, add-ons, player count capped at 18, teammate search, dates and time slots with seats left (stopped before Book & pay)
- FAIL — Add-on quantity, prices, step order (H-2, M-8)
- PASS — Chat: messages reach admin within seconds and admin replies arrive live; HTML shown as text; emoji and Arabic fine
- PASS — Offline: clear "Can't reach the Havoc server" message with Try again, and failed messages can be retried
- PASS — Profile photo: system photo picker, crop, upload, replace, remove; denying the camera shows a helpful message
- PASS — Delete account needs a password and rejects a wrong one with a clear error
- PASS — Session survives force-close; after sign out, Back exits the app and deep links lead to Sign In
- PASS — Help page is complete and clear; Blocked players has an empty state
- PASS — No crashes and no JavaScript errors in the logs for the whole session
- FAIL — Player directory, email verification, language, polish (M-11 to M-13, L-12, L-13)

Admin · logged out

- PASS Login form marks both fields required, and password managers can fill it
- PASS Staff pages such as `/players` send you to the login page when logged out
- PASS No source code, keys or secrets exposed in the site's code
- PASS X-Frame-Options DENY, nosniff and a referrer policy are set
- PASS Public pages render at 390px phone width with no sideways scrolling
- FAIL Public pages' hosting and titles, delete form, headers, 404 handling (M-3, M-4, L-8, L-9)

Admin · logged in

- PASS Session cookie is HttpOnly (page scripts can't read it), no tokens in browser storage, and the profile API returns no sensitive fields
- PASS API responses take 100–300 ms
- PASS Player search: ignores letter case, matches part of a phone number, has an empty state, and handles special characters (% and _ are treated as text)
- PASS Edit player modal: Escape closes without saving; admin can set a new password for a player
- PASS Delete actions use in-page confirmations that name the record
- PASS Offers: reversed dates and empty offers blocked, HTML shown as text, emoji and Arabic fine, edit persists after reload, delete works
- PASS SkipCash secrets are write-only fields
- PASS Leaderboard maths is correct (efficiency = kills ÷ KIA, accuracy = hits ÷ shots)
- PASS A player registered in the app appears in admin right away
- FAIL Payments mode, pricing, booking states, imports, layout (C-1, H-2, M-6 to M-10, L-10, L-11)

Not tested, on purpose

This is the live production system, so I skipped anything that would take real money, change real customers' data, or reach real players:

AREA	WHY IT WAS SKIPPED	HOW TO COVER IT
Book & pay, SkipCash page, payment return, auto-cancel	Would create a real booking in Bookeo and hold a real slot	Run on a staging Bookeo + SkipCash sandbox, or book a slot yourself and cancel it
Admin: create or edit bookings	Syncs to the live Bookeo calendar	Same as above
Settings, SkipCash "Test connection" or "Remove"	Changes live payment config	Do it while fixing C-1
Chatting with real players, blocking or reporting them	Would message or affect real customers	Use two test accounts
Admin logout, login lockout	Logging out would end the session, and I don't enter passwords on live systems	Quick manual check
Rate limiting on the delete-account form	Would mean hammering production	Ask the backend team, or test on staging
Offer image upload, stats PDF import	Would publish content or change the live leaderboard	Staging, or a hidden offer dated in the future

Test data left behind

- Admin offer `QA_TEST_offer…` (hidden, dated 2030): created, edited and **deleted**.
- The test player `@laith123` (your account) now has a plain red profile photo and a chat with **admin** containing 3 messages marked `QA_TEST`. Delete the account from the app or admin when you're done with it.
- No bookings, payments, settings changes or messages to real players.

Evidence (screenshots, UI dumps, crash and session logs, manifest dump, admin notes) is saved in `~/Desktop/projects/havoc-qa/`.

Tested 11 Nov 2026 · emulator Pixel_6_API_34 · Chrome desktop.